

Isolating Compromised Host Using 5-Tuple



SGUIL

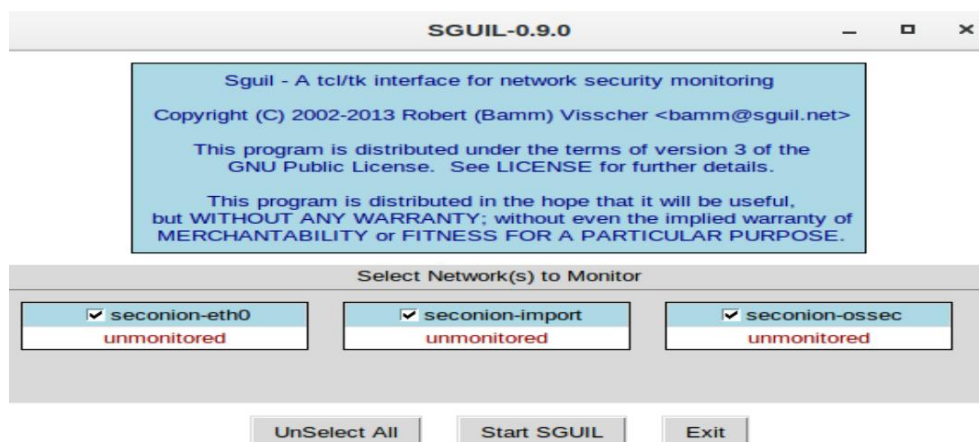
- Note. 5-tuple is used to identify network flows for various uses like firewall inspection and ACLs.

A 5-tuple is (Source IP, Destination IP, Source Port, Destination Port, Protocol)

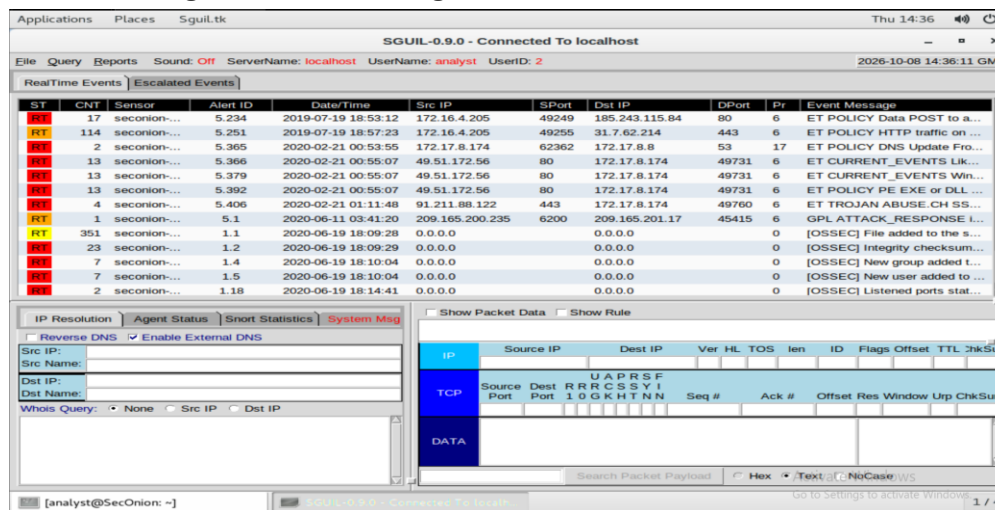
Context

After the machine is compromised, the user lost access to *confidential.txt* file.

Let's use SGUILL for this:



When reading the event messages



One stood out to me, one returned by OSSEC, a host-based IDS, which is **“GPL ATTACK_RESPONSE id check returned root”** which means a root access may have been given

after an attack!

RT	1	seconion-import-1	5.1	2020-06-11...	209.165.200....	6200	209.165.20...	45415	6	GPL ATTACK_RESPONSE id check returned root
----	---	-------------------	-----	---------------	-----------------	------	---------------	-------	---	--

More details about the alert could be inspected to further understand why the alert was shown:

☒ Show Packet Data☒ Show Rule

alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root"; content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown; sid:2100498; rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23;)/nsm/server_data/securityonion/rules/seconion-import-1/downloaded.rules: Line 700

IP	Source IP		Dest IP		Ver	HL	TOS	len	ID	Flags	Offset	TTL	chkSum				
	209.165.200.235		209.165.201.17		4	5	0	76	31846	2	0	64	3506				
TCP	U A P R S F																
	Source Port	Dest Port	R R R	C S S	Y I	Seq #		Ack #		Offset	Res	Window	Urp	ChkSum			
	6200	45415	.	.	X	X	.	.	2951186435	1436935650	8	0	181	0	29271		
DATA	75 69 64 3D 30 28 72 6F 6F 74 29 20 67 69 64 3D uid=0(root) gid=0(root).																
	30 28 72 6F 6F 74 29 0A																

Let's also have a look at the transcript to see what really happened:

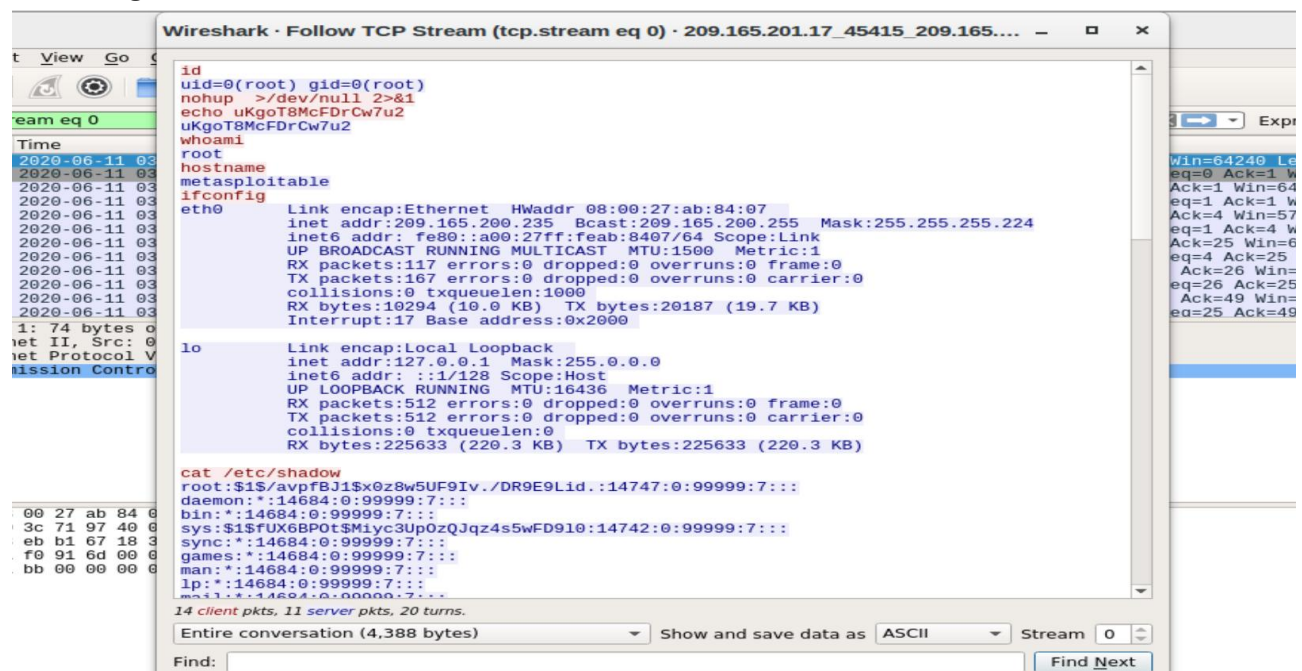
seconion-import-1_1	
Elle	
Sensor Name: seconion-import-1	
Timestamp: 2020-06-11 03:41:20	
Connection ID: seconion-import-1_1	
Src IP: 209.165.201.17	
Dst IP: 209.165.200.235	
Src Port: 45415	
Dst Port: 6200	
OS Fingerprint: 209.165.201.17:45415 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7:..?:?] (up: 6267 hrs)	
OS Fingerprint: -> 209.165.200.235:6200 (link: ethernet/modem)	
SRC: id	
SRC: DST: uid=0(root) gid=0(root)	
SRC: nohup >/dev/null 2>&1	
SRC: echo uKgoT8McFDrCw7u2	
SRC: DST: uKgoT8McFDrCw7u2	
SRC: whoami	
SRC: DST: root	
SRC: hostname	
SRC: DST: metasploitable	
SRC: ifconfig	
Search Abort Close	
Debug Messages	
/tmp/209.165.201.17:45415_209.165.200.235:6200-6.raw (ip and host 209.165.200.235 and host 209.165.201.17 and port 6200 and port 45415 and proto 6) or (vlan and host 209.165.200.235 and host 209.165.201.17 and port 6200 and port 45415 and proto 6)	
Finished.	

we can see the attacker now has root access on the victim machine, as shown from the commands they ran.

Let's Pivot to wireshark now, to have an even more detailed view

Wireshark

Following the TCP stream confirms it:



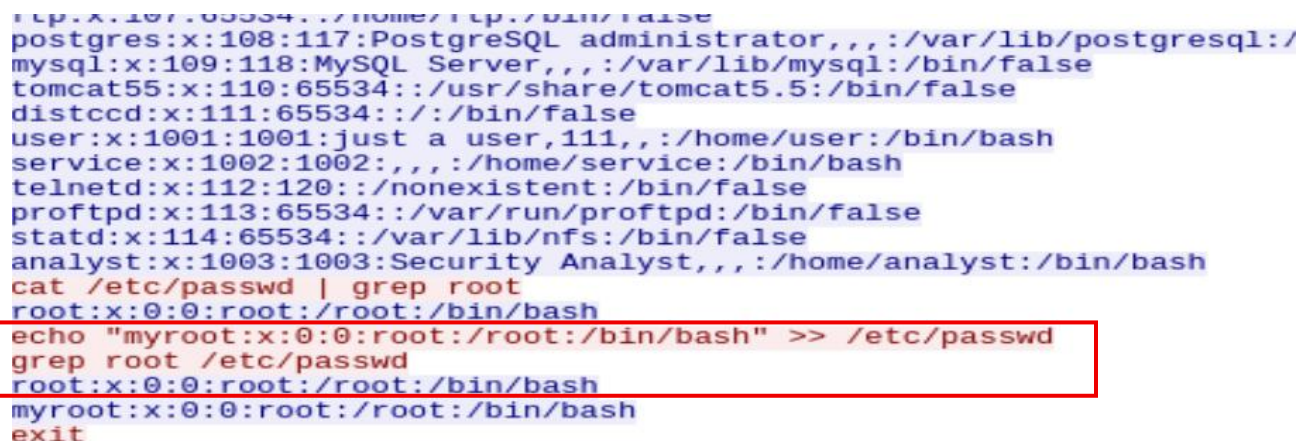
We can first see that the attacker tried:



Which, after a small research:

Appending a malformed line with the wrong number of fields can cause system authentication tools (like `passwd`, `ssh`, or `sudo`) to misread the file. This can lead to system-wide lockouts or prevent legitimate users from logging in.

Also they injected a backdoor user to access the system with no password:



KIBANA

Let's use how the file was exfiltrated, let's check FTP on the KIBANA dashboard

By following the IP addresses into KIBANA, we found ftp sessions

All Logs

Time	source_ip	source_port	destination_ip	destination_port	uid	_id
June 11th 2020, 03:52:26.226	192.168.0.11	52776	209.165.200.235	21	C5GkeA48oXZdWTPY0	EDqy08B6Ca_055_gy
June 11th 2020, 03:41:30.775	209.165.201.17	57761	209.165.200.235	21	C48m32oCvMM4Mcw	7Fp0886cd_0v63

Suspicion confirmed

Argument	Count
192,168,0,11,194,153	1
ftp://209.165.200.235/./confidential.txt	1

Following the pcap transcript shows the credentials used for the transfer

[192.168.0.11:52776 - 209.165.200.235:21-6-1009586379.pcap](#)

```
Log entry:
{"ts":"2020-06-11T03:53:09.086840Z","uid":"C5GkeA48oXZdWTPY0","id_orig_h":"192.168.0.11","id_orig_p":52776,"id_resp_h":"209.165.200.235","id_resp_p":21,"user":"analisys","password":"","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete","uid":"FX1V63eSMAEIN1652"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 52776
Dst Port: 21
OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [544-63:1:60:M1460,S,T,N,W7...7] (up: 3131 hrs)
OS Fingerprint -> 209.165.200.235:21 (link: ethernet/modem)
DST: 226 (vsFTPD 2.3.4)
DST:
SRC: USER analisys
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
```

Let's see the file that was exfiltrated, it is a text file:

host	192.168.0.11	209.165.200.235
ips	192.168.0.11	209.165.200.235
is_orig	192.168.0.11	209.165.200.235
md5	192.168.0.11	209.165.200.235
message	192.168.0.11	209.165.200.235
type	192.168.0.11	209.165.200.235

And following the pcap transcript shows the contents in plain text since it's over (unsecure) ftp:

```
192.168.0.11:49817 - 209.165.200.235:20-6-706324792.pcap

Log entry:
{"ts":"2020-06-11T03:53:09.088773Z","uid":"FX1V63eSMAEIN1652","tx_hosts":["192.168.0.11"],"rx_hosts":["209.165.200.235"],"conn_uids":["C2Jv8MWV6Xg48b51"],"source":"FTP_DATA","depth":0,"analyzers":["SHA1","MD5"],"mime_type":"text/plain","duration":0.0,"is_orig":false,"seen_bytes":102,"missing_bytes":0,"overflow_bytes":0,"timedout":false,"md5":"e7bc9c20bd9566365379c91294d536b","sha1":"7754acee0342f0161f6e03a10624ee11b330725"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
SRC: CONFIDENTIAL DOCUMENT
SRC: DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:

DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
QUERY: SELECT id FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
CAPME: Processed transcript in 0.34 seconds: 0.09 0.15 0.00 0.10 0.00
```